

Kommen wir zum Modul 5, Datenschutz und IT -Sicherheit bei der Nutzung von KI. Wie kriegen wir es denn hin, dass der Einsatz von KI im Unternehmen auch datenschutzkonform ist und man sich keine Probleme damit macht und nicht schlecht schlafen muss, weil man gegen die DSGVO verstößt oder weil auf einmal die eigenen Daten im Datennet landen. Das ist Ziel dieses Moduls. Eine kleine Einführung. Warum ist Datenschutz bei der Nutzung von KI so wichtig? Wenn man die KI nutzt, kann es sehr gut sein, dass man auch sensible Daten verarbeitet. Personenbezogene Daten, Daten von Kunden, biometrische Daten, Fotos, die dann im Internet sind und nicht mehr gelöscht werden können. Das kann zu Risiken für Unternehmen führen, die wirklich gefährliche Auswirkungen haben können. Rechtliche Konsequenzen, Reputationsverlust, weil sich Kunden beschweren, weil die Daten verloren gegangen sind. Und es kann sein, dass man viel Informationen weiterleitet und deswegen Probleme kriegt. Und außerdem, und da kann ich aus Erfahrung sprechen als Datenschutzbeauftragter, ein Datenschutzauditor ist immer blöd, wenn man Probleme mit der DSGVO kriegt, weil die ist sehr scharf geschaltet. Und da sollte man tunlichst darauf aufpassen, dass man da keine Bußgelder kassiert oder Abmahnung, wie es mittlerweile auch häufiger vorkommt. Welche Daten sind besonders kritisch bei der Nutzung von KI? Es ist so, wenn man jetzt beispielsweise hinget und sagt, okay, entwickle mir jetzt mal ein Logo oder schreib mir mal einen netten Werbetext zu Getränk XY oder sowas und da keine personenbezogenen Daten oder kritische Daten oder wichtige Unternehmensdaten drin sind, dann ist das erstmal unkritisch zu bewerten. Allerdings ist alles, was Personenbezug hat, dann immer direkt in der Anwendungsbereich der Datenschutzgrundverordnung. Und da muss man dann gucken. Natürlich sind auch Unternehmensdaten zu schützen nach dem Hinweisgeberschutzgesetz. Das ist eine wichtige Sache. Aber da sind wir in den entsprechenden Modulen schon drüber eingegeben. Wenn wir jetzt über Datenschutz reden, ist es wichtig, auf welche Daten muss man besonders achten. Man nennt es Artikel 9 Daten in der DSGVO. Das sind Daten zum Beispiel zur ethnischen Herkunft, zur sexuellen Ausrichtung, biometrische Daten, wie zum Beispiel die zur Gesichtserkennung führen, kann eindeutige körperliche Merkmale. Ein Iris -Scans zum Beispiel, Fingerabdruck, wenn man sich irgendwo einloggt oder sein Handy bedient. Das sind biometrische Daten, die haben einen sehr hohen Schutzbedarf. Fotos mit identifizierbaren Personen sind mittlerweile sehr, sehr einfach rausgesucht und können einer Person zugeordnet werden. Aber auch scheinbar harmlose Daten, wo man gar nicht so groß darauf achtet, wie in der HR -Abteilung zum Beispiel Bewerbungen oder wenn man ein Zeugnis schreibt. Auch das sind alles Daten, die datenschutzrechtlich relevant sind. Und natürlich, der Klassiker sind die Gesundheitsdaten. Die sind besonders schutzwürdig. Ein Beispiel wäre hier die elektronische Patientenakte und wie man damit umgehen sollte. Wer trägt denn die Verantwortung, die datenschutzrechtliche Verantwortung? Viele meinen, das wäre der Anbieter des KI -Tools. Allerdings ist es so, dass der Nutzer, das Unternehmen verantwortlich bleibt. Wenn das Unternehmen sagt, okay, wir nutzen jetzt ein KI -Tool, dann trägt es die datenschutzrechtliche Verantwortung. Man muss selber prüfen, wie sieht sie aus, wo gehen die Daten hin, wer hat Zugriff auf diese Daten. Das ist geregelt in Artikel 5 Absatz 2 DSGVO. Da steht ganz klar drin, dass das Unternehmen hier verantwortlich bleibt. Und auch die Nachweispflicht hat. Man nennt es Rechenschaftspflicht, dass der Mitarbeiter und größer gesehen das Unternehmen immer nachweisen muss, okay, so gehen wir damit um. Das sind unsere Richtlinien und muss das alles in Verzeichnung von Verarbeitungstätigkeiten, in der Dokumentation oder in den technischen und organisatorischen Maßnahmen zur Datensicherheit alles dokumentieren. Man kann also nicht hingehen und sagen, man gibt die Datenschutzverantwortung weiter an den Anbieter oder an den Endnutzer, also den Mitarbeiter, sondern verantwortlich bleibt das Unternehmen. Was hat das zur Folge? Man hat Informationspflichten in der DSGVO. Die sind unter anderem in Artikel 13 und 14 geregelt. Der Betroffene muss bei der Erhebung der Daten darüber informiert werden, was passiert mit den Daten. Wo gehen die Daten hin? Wo werden die gespeichert? Wie lange werden sie gespeichert? Wer hat Zugriff darauf? An wen werden sie weitergegeben? Das muss alles in verständlicher, klarer, transparenter Form geschehen. Und auch wenn das ein technisch komplexes Thema ist, müssen diese Informationen trotzdem jedem zugänglich sein und jeder muss sie auch verstehen können. Man kann das lösen mit zum Beispiel so kleinen Bildern, wo dann drauf steht,

EU oder durchgestrichene EU, dass die Daten weitergegeben werden. Und es bringt nichts, wenn man sich hinter 50 Seiten Datenschutzerklärung versteckt, sondern es muss wirklich transparent sein. Und jeder Endverbraucher muss sehen können, okay, was passiert hier mit den Daten. Und für die Rechtssicherheit, dass man wirklich sagen kann, okay, wir nutzen dieses Tool so, dass es vernünftig ist und dass wir den Anforderungen entsprechen, muss man diese Informationen transparent an den Betroffenen, das heißt an die Person, dessen Daten wir weitergeben, mitteilen. Ausgeschlossene DSGVO ist die sogenannte automatisierte Entscheidungsfindung. Auch wenn man, wenn das häufig anders gemacht wird, man denke an Kreditvergaben, man gibt irgendwo auf einer Webseite ein und möchte irgendwas vielleicht auf Kredit kaufen und wird sofort abgelehnt. Dann kann man immer schon sicher sein, ah, okay, da hat eine automatisierte Entscheidungsfindung stattgefunden. Wenn man wegen eines schlechten Schufa -Scores zum Beispiel sofort aussortiert wird, ist das immer ein Problem. Es muss am Ende immer ein Mensch drüber gucken. Man nennt es Human in the Loop. Am Anfang steht der Mensch, dann macht die KI ein Output und am Ende muss nochmal ein Mensch drüber gucken. Ähnlich ist es bei Bewerbungen. Man kann jetzt nicht verschiedene Bewerbungen nehmen und der KI sagen, okay, jeder, der zehn Rechtschreibfehler gemacht hat, wird direkt aussortiert. Jeder, der älter ist als so, jeder, der jünger ist als so, wird komplett aussortiert. Man kann das als Entscheidungsgrundlage nehmen, aber die letztendliche Entscheidung darf nicht automatisiert erfolgen, sondern muss von dem Menschen selber erfolgen. Weiter ist es zu beachten, das ist besonders wichtig für die Unternehmensleitung, dass geklärt ist, datenschutzrechtlich, was passiert mit diesen Daten, wenn personenbezogene Daten im Auftrag verarbeitet werden, bedarf es eines sogenannten AVV, eines Auftragsverarbeitungsvertrags oder einer Vereinbarung zur Auftragsverarbeitung und da sind die Sachen geregelt, was mit diesen Daten passieren kann. Da muss die Unternehmensleitung, die, wie wir gelernt haben, verantwortlich ist, diese Regelungen beachten und diese Verträge schließen. Ein wichtiges Thema bei der Nutzung von KI ist die Datenübertragung in Drittstaaten. Ganz viele von den Big Playern haben ihren Sitz nicht in Europa, sondern in Amerika oder China zu großen Teilen. Datenschutzrechtlich ist es so, dass immer wenn personenbezogene Daten in ein nicht sicheres Drittland versendet werden, dass es da zu Problemen kommen kann, dass man da wirklich gucken muss, okay, wie regeln wir das jetzt. Man braucht entweder einen Angemessenheitsbeschluss, beispielsweise die ganzen Länder aus der EU, da gibt es keine Probleme, da ist alles das gleiche Datenschutzniveau. Es gibt Länder mit Angemessenheitsbeschluss wie Japan, Kanada, wo es auch kein Problem gibt und dann gibt es unsichere Drittstaaten und das sind beispielsweise dann jetzt Amerika, China, Russland und da muss man dann gucken, wie macht man das. Kann man das mit zusätzlichen Verträgen machen, kann man das mit zusätzlich technischen Sicherungen machen, wie regelt man das oder nutzt man die Tools separat auf seinen eigenen Servern und schickt die Daten gar nicht nach Amerika oder man greift zu europäischen Dienstleistern. Auf jeden Fall muss man das beachten und kann nicht einfach, ohne reflektiert zu sein, ohne zu wissen, was da passiert, die Daten in unsichere Drittstaaten transferieren. Dann gibt es die Risiken bei öffentlich zugänglichen KI -Modellen. Das ist einmal die Datenspeicherung, was damit passiert, das KI -Training, dass die Daten dann von dem Hersteller genutzt werden und dass der eigene Input dann zum Output des nächsten wird. Das kann ein Problem sein, das ist bei den LLM -Modellen so, ChatGPT, Gemini, bei diesen ganzen Modellen ist es so, dass man darauf achten muss, okay, was passiert hier mit den Daten. Das kann zum Datenschutzrisiko führen, dass die personenbezogenen Daten weitergeleitet werden, ohne dass man wirklich eine Rechtsgrundlage dafür hat, eine Freigabe dafür hat oder eine Einwilligung dafür hat. Helfen können da interne, klare Regelungen, es muss kommuniziert werden, was mit den Daten passieren kann, die Mitarbeiter müssen geschult werden, da leisten wir hiermit einen Beitrag zu und es muss klare Richtlinien dazu geben. Kommen wir zu den technischen und organisatorischen Maßnahmen zur Datensicherheit. Auch die greifen hier bei der Nutzung von KI -Systemen. Auch hier muss das IT -Sicherheitskonzept befolgt werden. Die normal greifenden Pflichtmaßnahmen müssen beachtet werden, beispielsweise wer hat denn Zugriff auf dieses Tool, wer darf sehen, was der letzte im Unternehmen eingegeben hat. Diese Sachen müssen geklärt werden. Zugangsberechtigungen müssen vernünftig vergeben werden, es muss auf Verschlüsselung geachtet

werden und es muss gegebenenfalls auch nachvollziehbar sein, wer, wann, welche Änderungen. Dann müssen die Systeme, die man verwendet, kontinuierlich geprüft werden. Man muss gucken, okay, gab es Updates, haben die DAGBs verändert, gibt es neue Datenschutzrichtlinien. Man muss immer mal drüber gucken, okay, ist das, was man vielleicht von einem halben Jahr abgeschlossen hat, in dieser schnelllebigen Zeit, ist das noch aktuell. Ein großes Risiko ist, wenn es so viele Regelungen gibt und viele Unternehmen hingehen und grundsätzlich sagen, nee, KI, damit wollen wir nichts zu tun haben, ist, dass es zur Schatten -KI kommt. Man kennt vielleicht die Schatten -IT, dass jemand seinen eigenen Laptop oder Handy für Sachen benutzt, weil da alles freigeschaltet ist oder weil es vielleicht schneller ist als die Sachen im Unternehmen und genau das Problem haben wir auch bei der Nutzung von KI. Wenn die grundsätzlich verboten ist oder nur eingeschränkt nutzbar ist, dass man dann das Handy unterm Tisch rausholt und Sachen bei ChatGPT eingibt, die man eigentlich nicht dürfte. Das kann zu Kontrollverlust führen und zu Datenschutzverletzungen. Das kann große Probleme geben. Lösungen sind klare interne Vorgaben. Schulungen zu erlaubten KI -Tools und Freigabeprozesse. Und ich würde damit Whitelisting arbeiten. Das heißt, man sagt, okay, diese Tools dürfen genutzt werden, diese und grundsätzlich alle anderen dürfen nicht genutzt werden. Und wenn dann ein Mitarbeiter sagt, okay, aus dem und dem Grund würde ich gerne dieses Tool nutzen, sollte man dem auch offen gegenüberstehen und das diskutieren und beraten und nicht einfach nur sagen, nein, wir haben ein Tool und alles andere darf nicht genutzt werden, weil dann kann es zu dieser Schatten -KI kommen. Ein Problem, was KI und Datenschutz angibt, ist auch die Manipulierbarkeit. Die KI ist anfällig für Manipulation. Durch Prompt -Injection, durch fehlerhafte Trainingsdaten kann es dazu kommen, dass falsche Empfehlungen gegeben werden, dass Sicherheitslücken aufgemacht werden, dass falsche Entscheidungen getroffen werden oder dass man einfach falsch berät oder Daten weitergegeben werden. Schutzmaßnahmen kann sein, die Trainingsdaten prüfen, den Output prüfen, gucken, okay, Reasoning, wie ist die KI dazu gekommen, diese Sachen rauszugeben und die Quellen nochmal zu prüfen und nicht einfach nur ungeprüft die Daten, die man bekommen hat, weiterzugeben. Es muss klare Vorgaben geben. Datenminimierung gibt nur das ein, was wirklich sinnvoll ist, was notwendig ist für diesen Zweck, für diese Verarbeitung und die Zweckbindung. Nur weil man ein Datum hat oder verschiedene Daten hat, darf man die nicht für alles verwenden. Es grillt das Prinzip der Zweckbindung. Dann muss man regelmäßig testen, wie sieht es aus, ist das KI -Modell noch nach dem Standard, den man gewohnt ist oder ist es Manipulierbarkeit und man sollte häufiger mal einen Test machen mit einem Thema, wo man gut drin ist, um zu gucken, okay, ist der Output vernünftig. Soweit zu den Themen Datenschutz und IT -Sicherheit bei der Nutzung von KI.